Saudi GRC Platform

Module Architecture

Source: `module-architecture.md`

02 — Module Architecture

Per-module breakdown. Every module follows the layered layout under `tss-grc-backend/src/main/java/com/tss/grc/module/{name}/` with `controller/`, `dto/`, `entity/`, `repository/`, `service/`. Frontend pages under `tss-grc-ui-v2/src/pages/{slug}/`.

---

1. Enterprise Risk Management (ERM)

Description	ISO 31000-aligned end-to-end risk programme: appetite, identification, assessment, treatment, KRIs, scenarios, emerging risk, committee oversight.
Business purpose	Quantify and govern enterprise risk, demonstrate board-level oversight, escalate when appetite is breached.
Personas	Risk Manager, Risk Owner, Control Owner, Risk Committee Chair, Executive Reviewer
Core workflows	Risk lifecycle DRAFT→IN_REVIEW→ACTIVE→ACCEPTED /MITIGATED/CLOSED; KRI breach event; Risk acceptance with signature; Scenario approval; Emerging risk HORIZON →MONITORING→ESCALATED/MATURED/DISMISSED
Registers	risk.risks, risk.risk_assessments, risk.risk_appetite_statements, risk.kri_definitions, risk.kri_breach_events, risk.scenarios, risk.emerging_risks
Data objects	Risk, RiskAssessment, RiskAppetiteStatement, KriDefinition, KriBreachEvent, RiskScenario, EmergingRisk, Issue
Screens	RiskRegisterPage, RiskDetailPage, RiskLifecyclePage, AppetiteBreachFeed, NewRiskModal, RiskScenariosPage, EmergingRiskPage
Key fields	code, titleEn/Ar, category, likelihood, impact, inherentScore, residualScore, treatment, owner, appetiteBand, kriValue, breachThreshold, scenarioType (MONTE_CARLO|STRESS_TEST|WHAT_IF)
Approval points	Risk acceptance (requires digital signature for above-appetite); Scenario approval; Emerging risk escalation
Evidence	Risk acceptance memo, scenario calculation pack, KRI monthly snapshot, committee minutes
Reports	Board Risk Report (PDF), Top-10 risks, Appetite breach feed, Heatmap
Integrations	→ CAPA (treatment plans), → Compliance (control linkage), → Incident (issue from incident), → Signature (acceptance), → Reporting

2. Business Continuity Management (BCM)

Description	ISO 22301-aligned BCM: critical services, BIA, BCP, IT DRP, exercises, crisis activation.

Business purpose	Quantify business impact, prove ability to recover within RTO/RPO, demonstrate exercise + lessons-learned discipline.
Personas	BCM Manager, BIA Owner, Service Owner, DR Owner, Crisis Manager
Core workflows	BIA scoring; BCP build + approve; DRP playbook test; Exercise schedule→run→after-action; Crisis activation → invocation → stand-down
Registers	bcm.critical_processes, bcm.bia_records, bcm.bcm_plans, bcm.dr_plans, bcm.exercises, bcm.invocations, bcm.crisis_*
Data objects	CriticalProcess, BiaRecord, BcmPlan, DisasterRecoveryPlan, BcmExercise, CrisisCommsTemplate, CrisisAudience, CrisisDistribution
Screens	BcmPage, BcmLifecyclePage, BcmDependencyPage, DrPlansPage, CrisisManagementPage
Key fields	mtpd, rto, rpo, mbco, serviceCriticality, siteType (HOT|WARM|COLD|ACTIVE_ACTIVE|CLOUD_DR), failoverStepsJson, failbackStepsJson, lastTestedAt, nextTestDue
Approval points	BIA sign-off (Service Owner + Risk Manager); BCP approval (BCM Manager); DRP approve+activate; Crisis declare
Evidence	BIA report, BCP document, DRP playbook, exercise after-action, crisis log, attestation
Reports	BCM Readiness Report, Critical-services continuity report, DR readiness, Crisis exercise after-action
Integrations	→ ERM (treatment links), → SCM (vendor dependencies), → Cyber (asset criticality), → CAPA (action items)

3. Supply Chain Resilience (SCM)

Description	Vendor register, dependency map, alternate suppliers, exit plans, resilience tests, fourth-party exposure, contract clause library.
Business purpose	Map and reduce single-supplier risk; ensure tested fallbacks for critical vendors; demonstrate SAMA outsourcing compliance.
Personas	Supplier Manager, Procurement Owner, Vendor Risk Manager, BCM Officer
Core workflows	Vendor register + criticality; Alternate supplier maintenance; Exit plan + rehearsal; Resilience test (tabletop/failover/exit-rehearsal/SLA/joint-crisis); Fourth-party validation + mitigation; Contract clause approval
Registers	scm.vendors, scm.alternate_suppliers, scm.exit_plans, scm.supplier_resilience_tests, scm.fourth_party_exposures, scm.contract_clauses, scm.dependencies, scm.slas, scm.supplier_incidents

Data objects	Vendor, AlternateSupplier, ExitPlan, SupplierResilienceTest, FourthPartyExposure, ContractClause, Dependency, Sla, SupplierIncident, VendorAssessment
Screens	ScmPage, SupplierResiliencePage, ResilienceTestsPage, FourthPartyPage, ContractClausesPage, DependencyMap, VendorDetailPage, VendorPortalPage
Key fields	criticality, country, alternateVendorRole, contractualStatus, scenarioScope, outcome (PASS|PASS_WITH_OBSERVATIONS|FAIL|NOT_RUN), rtoTargetMinutes, concentrationRisk (LOW|MEDIUM|HIGH), flowDownClausesPresent
Approval points	Alternate-supplier APPROVED; Exit-plan APPROVED + ACTIVATED; Resilience-test COMPLETED→APPROVED; Fourth-party VALIDATED→MITIGATED; Contract clause APPROVED
Evidence	Vendor due-diligence pack, alternate-supplier vetting, exit-plan minutes, test after-action, fourth-party validation memo, contract addendum
Reports	Supplier resilience report, Concentration risk heatmap, Upcoming tests calendar, Exit-plan readiness
Integrations	→ TPRM (cyber assessment), → BCM (vendor → critical process), → Compliance (contract clauses), → CAPA (FAIL → CAPA), → Signature (exit-plan sign-off)

4. NCA Cybersecurity Compliance

Description	NCA framework catalogue (ECC, CSCC, CCC, OTCC) + control libraries + self-assessment + filing + incident notification.
Business purpose	Demonstrate compliance with NCA Essential Cyber-security Controls and the supplementary CSCC (cloud customer), CCC (cloud provider), OTCC (OT) suites; produce the annual self-assessment filing.
Personas	Cybersecurity Manager, NCA Compliance Owner, Asset Owner, Vulnerability Manager, CISO
Core workflows	Framework applicability; Control assessment; Maturity scoring; Filing (NcaEccFiling); Cyber-incident NIST 800-61 lifecycle; Cloud (CCC) + OT (OTCC) specific checks
Registers	cyber.cyber_frameworks, cyber.cyber_controls, cyber.cyber_sub_controls, cyber.control_assessments, cyber.cyber_assets, cyber.cyber_incidents, cyber.vulnerabilities, cyber.exceptions, cyber.root_cause_analyses
Data objects	CyberFramework, CyberControl, CyberSubControl, ControlAssessment, CyberAsset, CyberIncident, Vulnerability, NcaEccFiling, RootCauseAnalysis
Screens	CyberPage, FrameworkControlsPage, CyberLifecyclePage, VulnerabilitiesV2Page, NcaEccExportPage, AssetRegisterPage, ControlDetailPage

Key fields	controlNumber, domain, maturityLevel (L1..L5), implementationStatus (IMPLEMENTED|PARTIAL|PLANNED|NOT_APPLICABLE|NOT_IMPLEMENTED), controlType, reviewFrequency, frameworkName
Approval points	Control assessment APPROVED; Filing SUBMITTED; Incident phase transitions (DETECTION→…→LESSONS_LEARNED); RCA APPROVED
Evidence	Control attestation, assessor working papers, scan reports, pentest letters, asset inventory, NCA filing PDF
Reports	NCA Compliance Report, NCA filing pack, Maturity heatmap, Cyber incident report
Integrations	→ ERM (cyber risk), → PDPL (cyber→breach bridge), → Evidence (control evidence), → CAPA (gap remediation), → Signature (filing CISO attestation)

5. PDPL / Data Privacy

Description	Personal data lifecycle aligned to PDPL + SDAIA: ROPA, notices, consent, DSR, PIA, breach, cross-border, disposal, data sharing, processor due-diligence.
Business purpose	Demonstrate full PDPL compliance; meet the 30-day DSR SLA and 72-hour breach-notification deadline; document Art. 28 processor controls and Art. 29 cross-border mechanisms.
Personas	Data Protection Officer (DPO), Privacy Manager, Data Owner, Legal Reviewer
Core workflows	ROPA maintenance; Privacy notice DRAFT→PUBLISHED→ARCHIVED; Consent capture+withdrawal; DSR intake→fulfil (30 days); PIA DRAFT→IN_REVIEW→APPROVED; Breach detection→72h regulator notify→close; CBT REQUESTED→ASSESSED→APPROVED; Disposal SCHEDULED→IN_PROGRESS→COMPLETED→VERIFIED; DSA DRAFT→IN_REVIEW→ACTIVE→EXPIRED/TERMINATED; Processor assessment IN_PROGRESS→COMPLETED→APPROVED/REJECTED
Registers	privacy.processing_activities (ROPA), privacy.privacy_notices, privacy.consents, privacy.dsr_cases, privacy.dpias, privacy.data_breaches, privacy.cross_border_transfers, privacy.disposal_certificates, privacy.data_sharing_agreements, privacy.processor_assessments, privacy.cyber_breach_bridge_log
Data objects	ProcessingActivity, PrivacyNotice, Consent, DataSubjectRequest, Dpia, DataBreach, CrossBorderTransfer, DisposalCertificate, DataSharingAgreement, ProcessorAssessment, CyberPdplBridgeEvent

Screens	PrivacyPage, PrivacyLifecyclePage, RopaPage, PdplExtensionsPage (data-lifecycle), DsrPortalPage, DpiaDetailPage, CyberPdplBridgePage, DataSharingPage, ProcessorAssessmentsPage
Key fields	lawfulBasis, dataCategories, dataSubjects, retentionPeriodDays, crossBorderMechanism (NONE|ADEQUACY|SCC|BCR|EXPLICIT_CONSENT…), c1..c8 control outcomes, breach 72h timer, disposalMethod (DELETE|ANONYMIZE|ARCHIVE|DESTROY)
Approval points	Notice PUBLISH; PIA APPROVE; Breach close; CBT ASSESS+APPROVE; Disposal VERIFY; DSA ACTIVATE; Processor assessment APPROVE
Evidence	DPO sign-off memo, signed notice, consent record, DSR response pack, PIA report, breach notification, CBT contract addendum, disposal certificate, processor audit pack
Reports	PDPL Compliance Report, DSR SLA dashboard, Breach register, Cross-border register, Processor due-diligence pack
Integrations	→ Cyber (cyber-bridge automated breach trigger), → SCM (vendor → processor), → CAPA (failed Art. 28 → CAPA), → Signature (DPO/CISO attestation), → Reporting

6. Regulatory Compliance

Description	Framework catalogue, requirement library, control mapping, attestation campaigns, regulatory feed, MOC/HRSD/SAMA panels, policy lifecycle.
Business purpose	Unify regulatory obligations across NCA + SDAIA + SAMA + MOC + HRSD + ISO; track requirement-to-control coverage; run attestation cycles.
Personas	Compliance Officer, Control Owner, Internal Auditor, Legal Reviewer
Core workflows	Framework activation; Requirement mapping; Control assessment; Attestation campaign (CCM); Regulatory change capture + impact; Policy DRAFT→APPROVED→ACTIVE→SUPERSEDED
Registers	compliance.frameworks, compliance.controls, compliance.requirements, compliance.assessments, compliance.policies, compliance.regulatory_changes, compliance.attestation_campaigns
Screens	CompliancePage, FrameworkPacksPage, PolicyTemplatesPage, PolicyDetailPage, RegulatoryChangePage, AttestationCampaignsPage, ControlCrosswalkPage, MocPanel, HrsdProcessInitiation, NitaqatPanel
Key fields	frameworkCode, requirementRef, controlNumber, attestationCycle, policyStatus (DRAFT|APPROVED|ACTIVE|SUPERSEDED), regulatoryImpact

Approval points	Policy approve/supersede; Framework activate; Attestation cycle close
Evidence	Policy PDF, attestation responses, regulatory citation, control crosswalk
Reports	Regulatory Compliance Report, Attestation completion, Policy expiry forecast
Integrations	→ ERM (control→risk), → Cyber (NCA frameworks), → Privacy (PDPL requirements), → Reporting

7. Evidence Management

Description	Central evidence repository with versions, chain-of-custody hash, expiry, links to controls / workflows / risks.
Business purpose	One source of truth for "the document that proves we did this", with tamper-evident chain and audit linkage.
Personas	Evidence Owner, Control Owner, Auditor (internal + external)
Core workflows	Upload+version; Link to control/risk/incident; Approve; Verify chain; Expire+renew
Registers	evidence.evidence_items, evidence.evidence_versions, evidence.evidence_links, evidence.frameworks, evidence.controls, evidence.sub_controls, evidence.permissions
Screens	EvidencePage, EvidenceChainPage (SHA-256), FileUploadDemoPage, FrameworkPacksPage
Key fields	externalId, titleEn/Ar, currentVersionNo, chainStatus (VALID|BROKEN|UNVERIFIED), chainFirstBreakVersion, contentHashSha256, chainHashSha256, expiryDate
Approval points	Evidence APPROVE; Chain verify (on-demand)
Evidence about evidence	Audit log + chain hash report
Reports	Evidence pack export, Chain integrity report, Expiry forecast
Integrations	→ all modules (linked-evidence panels), → Signature (sign critical evidence)

8. Incident, Crisis & Regulatory Notification

Description	Unified incident management (security, BCM, supplier, privacy) with crisis activation and regulator-notification paths.
Business purpose	One front-door for "something went wrong"; correct routing to NCA / SDAIA / SAMA / CITC / HRSD timers; structured RCA + CAPA.
Personas	Incident Manager, SOC Lead, Crisis Manager, DPO, CISO, Regulatory Liaison

Core workflows	Incident lifecycle (NIST 800-61: DETECTION→ANALYSIS→CONTAINMENT→ERADICATION→RECOVERY→POST_INCIDENT→LESSONS_LEARNED); Crisis declare→invocation→stand-down; Regulator notify (NCA 2h critical, SDAIA 72h, SAMA bilateral); RCA (5-Whys/Fishbone/Pareto) DRAFT→IN_REVIEW→APPROVED; Auto-generate CAPAs
Registers	incident.incidents, incident.timeline_events, incident.lessons_learned, cyber.cyber_incidents, cyber.root_cause_analyses, bcm.invocations, bcm.crisis_*
Screens	IncidentsPage, CyberPage→Incidents tab, RcaPage, CrisisManagementPage, CyberPdplBridgePage
Key fields	severity, classification, impactedAssets, regulatorNotified, notificationReference, methodology (FIVE_WHYS|FISHBONE|PARETO|OTHER), problemStatement, recommendations
Approval points	RCA submit/approve; Lessons-learned approve; Regulator notification sign-off
Evidence	Incident timeline, RCA report, regulator notification receipt, lessons-learned memo
Reports	Cyber Incident Report, Data Breach Report (PDPL), Lessons-learned register
Integrations	→ PDPL (cyber→breach bridge), → CAPA (RCA→CAPA), → ERM (incident→issue), → Signature (notification sign-off)

9. Reporting and Dashboards

Description	Live dashboards, board-pack generator, scheduled reports, regulator-package exports.
Business purpose	Visualize the platform state at any altitude (board / executive / operational), produce the periodic + on-demand reports the regulators expect.
Personas	Executive Reviewer, Board Secretary, Compliance Officer, Auditor
Core workflows	Live dashboard refresh; Scheduled report run; Board-pack generation (PDF/PPTX); Regulator evidence-pack zip
Surfaces	DashboardPage (widget engine), Board Pack module, ReportSchedulesPage, NcaEccExportPage
Key features	Customisable widget layout, live STOMP refresh, ExportMenu (CSV/XLSX/PDF), bilingual report templates
Approval points	Board pack sign-off (digital signature); Regulatory pack approve
Reports	See /10-Reports-Dashboards/ for full catalogue
Integrations	Consumes all modules via realtime broadcaster

10. Administration, Configuration, and Workflow Engine

Description	Platform admin: tenants, users, roles, committees, white-label, notifications, workflow versioning, audit.
Business purpose	Operate the platform — tenant isolation, role-based access, workflow customisation, notification routing, audit log.
Personas	System Administrator, GRC Administrator, Workflow Designer
Core workflows	Tenant onboarding; User+role; Committee charter + meetings; Workflow version DRAFT→ACTIVE→DEPRECATED; Notification channel + outbox; White-label theme apply
Registers	iam.users, iam.roles, iam.permissions, admin.committees, admin.committee_meetings, workflow.workflows, workflow.workflow_versions, notification.outbox, notification.channels
Screens	AdminPage, OnboardingPage, CommitteesPage, WorkflowsPage, WorkflowVersionsPage, NotificationChannelsPage, NotificationOutboxPage, SsoConfigPage, MfaPage, WhiteLabelPage, SettingsPage
Key fields	organisationId, role-permission map, workflow definition (JSON), committee charter, channel type (EMAIL|SMS|WEBHOOK|TEAMS), mfa method
Approval points	Workflow promote to ACTIVE; Committee charter approve; Tenant activate
Evidence	Workflow change log, role assignment history, audit log export
Reports	User access matrix, Workflow inventory, Audit log report
Integrations	Underpins every module